

Post-Quantum Android Phone Signal Relay and the Coming Private Personal Revolution

A field report from GreyNOC Messenger 98 — a complete, end-to-end-encrypted, post-quantum messaging network whose entire backend is a phone in someone's pocket.

Thesis in one paragraph

For the first time, the three things you need to run sovereign, future-proof, private communications for the people you actually talk to have all become free or nearly free at the same moment: **standardized post-quantum cryptography** (NIST, 2024), **a pocket computer more capable than a 2005 server rack**, and **zero-config tunneling that punches a public address through any carrier NAT**. Put them together behind a relay that is *architecturally incapable of reading what it carries*, and a single person can stand up a messaging service — confidential against quantum adversaries, authenticated against impersonation, with no company, no datacenter, and no business model — in an afternoon. GreyNOC Messenger 98 is a working existence proof. This report describes what it is, why each piece matters now and not five years ago, and why the pattern it represents is the leading edge of a broader shift: the migration of personal infrastructure off platforms and back into personal hands.

1. The setup: three curves crossed

Revolutions in capability usually aren't one invention. They're the moment several independent cost curves cross zero at once.

Curve one — post-quantum crypto stopped being a research topic. In August 2024, NIST finalized the first post-quantum standards: **FIPS 203 (ML-KEM)**, the key-encapsulation mechanism formerly called Kyber), **FIPS 204 (ML-DSA)**, the signature scheme formerly called Dilithium), and **FIPS 205 (SLH-DSA)**, the hash-based SPHINCS+). Overnight, “quantum-resistant encryption” went from a thing you'd have to implement from a paper to a thing you `npm install`. The same primitives that protect government traffic are now a dependency you vendor into a static web bundle.

Curve two — the server got into your pocket. A mid-range Android phone has more cores, RAM, storage, and network throughput than the machines that ran entire web companies twenty years ago — plus a battery, an uninterruptible power supply, and a cellular uplink built in. It is, physically, a datacenter that fits in a hand and costs less than a month of cloud bills.

Curve three — reachability became free. The historical reason you *couldn't* self-host was the network: carrier-grade NAT, dynamic IPs, blocked inbound ports. That wall is gone. A tunnel daemon (Cloudflare Tunnel, in GreyNOC's case) dials *out* from the phone and presents a stable public hostname — `https://chat.grey-noc.com` — with valid TLS, no port forwarding, no static IP, no router surgery. The phone never accepts an inbound connection; it holds an outbound tunnel open and the world reaches it through that.

Any one of these alone is a curiosity. Together they collapse the barrier that made “run your own encrypted comms” the exclusive domain of companies with ops teams. That collapse is the revolution. The crypto is what makes it *worth* doing; the phone and the tunnel are what make it *possible to do alone*.

2. The worked example: GreyNOC's blind Android relay

GreyNOC is a retro-styled (Windows 98 / early-2000s AIM aesthetic) messenger, but underneath the nostalgia it is a serious piece of applied cryptography. The defining architectural choice is this:

The server is a signaling relay that is structurally incapable of reading private messages — and it runs on a phone.

2.1 The relay that can't read

Private conversations in GreyNOC never travel through the server as content. The server's job is **introduction, not delivery**. Two browsers that want to talk privately use the server only to exchange the WebRTC signaling (SDP offers/answers and ICE candidates) needed to find each other; once they connect, traffic flows **peer-to-peer over a DTLS-encrypted data channel**, and on top of that the application runs its own end-to-end layer. The topology is a star — a room “host” is the hub and each joiner opens one channel to it — but the host is a *member*, not the server. The server brokers the handshake and then is out of the loop.

This is the difference between a *platform* and a *relay*. A platform sees your messages and promises not to look. A relay never has them. The operator of a GreyNOC phone cannot produce your message history under subpoena, sell it to advertisers, train a model on it, or leak it in a breach — not because of policy, but because the bytes were never in plaintext on that device.

2.2 Post-quantum confidentiality (the harvest-now problem)

Every private room and DM derives its key with a **hybrid handshake: classical X25519 elliptic-curve Diffie–Hellman combined with ML-KEM-768**, run through HKDF into a per-room AES-

256-GCM group key. “Hybrid” is the deliberate, conservative choice the entire industry has converged on (Signal’s PQXDH, TLS deployments, SSH): the shared secret is safe if *either* primitive holds, so you get post-quantum protection without betting everything on a young algorithm.

Why does this matter *today*, before any quantum computer can break anything? Because of **harvest-now, decrypt-later**. An adversary with the budget to record encrypted traffic — a nation-state tapping a backbone, a cloud provider logging flows — can store your ciphertext now and decrypt it years later when a cryptographically relevant quantum computer exists. For anything whose secrecy has a long shelf life (your identity, your relationships, what you said), the threat clock started the day the traffic was first recorded, not the day the quantum computer boots. Classical X25519 alone is a deferred breach. The ML-KEM half closes it.

GreyNOC applies this not just to live chats but to **offline messages** — sealed mail left for a buddy who isn’t online. Those are the highest-value harvest target (they sit at rest as ciphertext), and they were the last classical gap to be closed.

2.3 The offline prekey directory: a blind key server

Offline messaging has a chicken-and-egg problem: you can’t run a live key exchange with someone who’s asleep. The standard answer is a *prekey* — a long-term key the recipient publishes in advance. GreyNOC’s twist preserves the blind-relay property:

- Each identity generates a long-term **ML-KEM-768 prekey**, **signs it with its own identity key**, and publishes it to the server.
- A sender fetches the recipient’s prekey and **verifies that signature itself**.

So the directory the server hosts is *self-authenticating*: the server cannot substitute its own key to mount a man-in-the-middle, because any tampered key fails the signature check on the sender’s device. The server is a blind key directory in exactly the way it is a blind message relay — it holds material it cannot forge and cannot read.

2.4 Post-quantum authentication (closing the MITM)

Confidentiality without authentication is half a guarantee. A post-quantum key exchange behind a *classically* signed handshake is only as strong as the classical signature against a live quantum man-in-the-middle — a future attacker who can forge the old signature can sit in the middle and negotiate two “secure” channels. So GreyNOC co-signs the handshake itself.

- Every handshake transcript is signed with **ML-DSA-65** (FIPS 204) *in addition to* the classical Ed25519 signature.
- Each device keeps a separate long-term ML-DSA key, **bound to its identity**, and **pins** the peer’s ML-DSA key on first contact (trust-on-first-use).

- On any later connection, a *changed* pinned key — the signature of a quantum-capable impostor swapping in its own key — **causes the link to be refused**.

Crucially, the canonical identity stays Ed25519. Migrating the *identity key itself* to ML-DSA would be a ~50–60× size increase and would break every stored friendship and entitlement keyed to the old key — a poor trade against a threat (signature *forgery*) that, unlike confidentiality, is not retroactive. The pragmatic answer is to add a post-quantum *co-signature* where it protects a live channel, and leave the identity key stable. This is the same judgment call the standards bodies make: deploy PQ key exchange urgently, migrate PQ signatures deliberately.

2.5 Out-of-band verification, made post-quantum

Trust-on-first-use has one hole: an attacker present at the *very first* contact. The classical defense is a **safety number** — a short value both parties read aloud to confirm no one is in the middle. GreyNOC keeps the familiar Ed25519 safety number and adds a **post-quantum safety number** that folds in both parties' ML-DSA keys. If a quantum man-in-the-middle sat at first contact, each side pinned a different key, so the two post-quantum numbers won't match — and the impostor is exposed by a thirty-second phone call.

2.6 The phone is the whole stack

None of this runs in a cloud. The production deployment is:

- **Node + Express + Socket.IO** bound to `127.0.0.1:6969` on an **Android phone running Termux**.
- **Cloudflare Tunnel** dials out and serves `https://chat.grey-noc.com` — no inbound ports, works behind carrier NAT, valid TLS.
- **PM2** supervises both the app and the tunnel; a **wake-lock + heartbeat** script and the **Termux:Boot** add-on keep them alive through Android's Doze power management and across reboots.

That is the entire backend. A phone, a free tunnel, and a process supervisor. The “datacenter” is on a nightstand.

3. Why this is a revolution and not just a hobby project

It's easy to file self-hosting under “hobbyist tinkering.” The reason this moment is different is that the **floor of required expertise and capital has dropped below the threshold of an individual**, while the **ceiling of what you get has risen to match what platforms offer**. Consider what a single person now controls that, a decade ago, required a company:

Sovereignty of data. There is no third party holding your messages who can be breached, subpoenaed, acquired, or have a change of heart in its terms of service. The relay can't read what it relays. You are not a tenant on someone's platform; you own the building.

Sovereignty of economics. There is no business model, because there is no business. No ads, because no ad inventory. No data sale, because no readable data. No "free tier" that is actually paying with surveillance. The marginal cost of a conversation is a few watts of phone battery.

Sovereignty over time. Post-quantum confidentiality means the privacy you have today doesn't quietly expire when the cryptographic landscape shifts. You are not building on a foundation with a known demolition date.

Sovereignty of trust. Authentication is rooted in keys the participants hold and can verify face-to-face via a safety number — not in a certificate authority, an identity provider, or a platform's account system. Trust is between people, mediated by math, not brokered by a company.

The shape of the last twenty years of consumer technology was *centralization for convenience*: we traded ownership for the fact that someone else ran the servers. Every one of those trades was rational at the time because running the servers was genuinely hard. The three curves crossing zero is what makes the trade newly *optional*. When the hard part stops being hard, the rational default flips — and the things people centralized for convenience start coming home. Encrypted chat is simply the first and most legible example, because it's where the harm of the old model (surveillance, breaches, deplatforming) was most visible and the new primitives (PQC, WebRTC, tunnels) line up most cleanly.

That is the "private personal revolution": not a single app, but the **re-domestication of personal infrastructure** — communications first, then storage, identity, presence, and the rest — onto hardware you own, secured by cryptography that outlives the threat, reachable by anyone without belonging to anyone.

4. An honest accounting of the limits

A revolution oversold is a revolution discredited. The same engineering culture that makes GreyNOC trustworthy — being precise about what is and isn't guaranteed — applies to the thesis. Here is what this architecture does **not** solve, stated plainly.

Metadata is not content, and metadata leaks. End-to-end encryption hides *what* you say, not *that* you spoke. The relay operator and the network can see connection times and patterns; WebRTC's peer-to-peer nature and STUN reveal IP addresses to the people you talk to. And the very tunnel that makes the phone reachable — Cloudflare, here — is a large intermediary that sees connection metadata even though it can't see message content. Reachability was bought with a centralized dependency. That's an honest tension: the data plane is sovereign and blind; the *reachability* plane is not yet.

Closing it (peer-discovered addressing, onion-routed signaling) is unfinished work, not a solved problem.

Endpoint compromise defeats everything. The keys live in a browser's local storage. A compromised device, a malicious extension, or a coerced unlock exposes them, and no amount of post-quantum handshaking helps once the attacker is *inside* one of the endpoints. E2E moves the trust boundary to the device; it does not eliminate it.

Trust-on-first-use is still trust-on-first-use. The post-quantum safety number closes the first-contact gap *if people actually compare it*. Most won't, most of the time. The protection is real and available; it is not automatic.

The identity key is still classical — on purpose. Signature forgery is a future capability, not a retroactive one, so the identity key remains Ed25519 to avoid a punishing size and migration cost. That's a defensible judgment, but it is a deferred item: a full identity migration is the right move if and when quantum computers get close, and it will need to be coordinated.

A phone is not five-nines. Doze, battery, a flaky cellular link, a reboot, a dropped tunnel — a nightstand server has the availability of a nightstand. Wake-locks and supervisors mitigate this; they don't turn a phone into a datacenter. Sovereignty has an uptime cost, and for some uses that cost is real.

Code is a trust root too. Owning the server doesn't help if you don't trust the client. The strict same-origin loading, vendored crypto bundle, and content-security policy are there precisely so the code you run is the code you can audit — but the user is still trusting the build, the same way they trust any software.

None of these are fatal. They are the honest edges of a real system, and naming them is what separates a working revolution from a slogan.

5. What it would take to generalize

GreyNOC is one instance of a pattern. For the pattern to become the *default* rather than the enthusiast's choice, a few things need to keep maturing:

1. **One-tap deployment.** “Install an app on an old phone, scan a code, you now run a relay for your family” — the tunnel, supervisor, keepalive, and keys provisioned automatically. The pieces exist; the packaging doesn't yet.
2. **Sovereign reachability.** Replacing the centralized tunnel with peer-discovered or relay-meshed addressing so the metadata plane becomes as blind as the data plane.

3. **Portable, recoverable identity.** Post-quantum identity keys with humane backup and rotation, so “I lost my phone” isn’t “I lost myself.”
4. **Federation without platforms.** Letting independently owned relays interconnect by mutual key agreement, so personal infrastructure composes into a network without anyone owning the network.

These are tractable engineering problems, not breakthroughs-in-waiting. That’s the tell that the curve has truly crossed: what remains is *product*, not *research*.

6. Conclusion

The interesting thing about GreyNOC is not the Windows 98 window chrome. It’s that a complete, post-quantum, end-to-end-encrypted messaging network — confidential against a future quantum adversary, authenticated against impersonation, blind at the relay, verifiable between humans — fits on a phone and answers to one person.

That is new. It is new because NIST standardized the algorithms, because the phone became a server, and because tunnels made any phone reachable — all within roughly the same eighteen months. When the cost of owning your own infrastructure falls below the cost of explaining why you don’t, people stop renting. The platforms of the last era were a rational response to hard problems that are no longer hard.

The private personal revolution is the unwinding of that bargain: encrypted communication you own, on hardware you hold, protected by mathematics built to outlast the threat — beginning with the device already in your pocket.

Grounded in the GreyNOC Messenger 98 codebase: hybrid X25519 + ML-KEM-768 confidentiality for rooms, DMs, and offline mail; ML-DSA-65 handshake co-authentication with trust-on-first-use pinning and a post-quantum safety number; a self-authenticating ML-KEM prekey directory; a blind WebRTC signaling relay served from Android/Termux via Cloudflare Tunnel under PM2. Cryptographic primitives are the @noble post-quantum and curves libraries; AES-256-GCM is the browser’s WebCrypto. See `docs/THREAT_MODEL.md` for the formal threat model and its stated non-goals.